

Controls and compliance checklist

Does Botium Toys currently have this control in place?

Controls assessment checklist

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☐	☒	Password policies
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☐	☒	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance
☒	☐	Fire detection/prevention (fire alarm, sprinkler system, etc.)

Does Botium Toys currently adhere to this compliance best practice?

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorised users have access to customers' credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☒	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers' data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☒	Ensure data is properly classified and inventoried.
☒	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organisations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☒	User access policies are established.

- | | | |
|-------------------------------------|-------------------------------------|--|
| ☐ | ☒ | Sensitive data (PII/SPII) is confidential/private. |
| ☒ | ☐ | Data integrity ensures the data is consistent, complete, accurate, and has been validated. |
| ☐ | ☒ | Data is available to individuals authorised to access it. |
-

Recommendations:

The recommendations to Botium Toys would be:

- Ensure data is properly classified and inventoried. Sensitive data, including PII and SPII, must be designated as confidential/private and handled accordingly.
- Implement and enforce Access Control Lists (ACLs) based on the principle of least privilege and separation of duties, ensuring that only authorised personnel can access and modify data. This is especially critical for restricting access to customers' credit card information and for maintaining compliance with PCI DSS and GDPR requirements.
- Enforce strong password policies supported by a password management system to better secure employee accounts and strengthen the overall internal network security posture.
- Establish comprehensive disaster recovery and business continuity plans, including the use of secure cloud-based backup SaaS solutions, to ensure data availability and operational resilience in the event of system failures or cyber incidents.
- Deploy Intrusion Detection Systems (IDS) to improve threat detection and incident response capabilities. This also supports regulatory compliance, such as the GDPR requirement to notify affected parties of a data breach within 72 hours.
- Improve manual monitoring, maintenance, and intervention procedures for legacy systems by implementing a regular maintenance schedule and clearly defined response processes. Where feasible, migrating from legacy systems to modern solutions is recommended to reduce the attack surface and mitigate associated security risks.
- Implement encryption for customer data both at rest and in transit to ensure confidentiality. This reduces the risk of data misuse in the event of a breach and is essential for securing credit card transaction touchpoints and maintaining PCI DSS compliance.

Implementing these recommendations would significantly reduce the risk of regulatory non-compliance and associated financial penalties, while strengthening the organisation's overall security and compliance posture.